PIDS Passau Institute of Digital Security

**Exercise Advanced IT-Security** **Winter term 2026**

**Exercise Sheet 1**
Date of discussion: 29. November 2026
Supervisor: Emiliia Gelóczi

General Information:

- No obligation to work on sheets.
- No amount of points required for exam participation.
- No compulsory attendance
- Weekly exercise courses with around 90 minutes of duration.

## Topic 1: Elements and Terminology in the Security Domain

a) Match each term (1–8) to the most appropriate definition (A–H).

| | |
|---|---|
| 1. Asset | A. A weakness that may allow a harmful event to occur. |
| 2. Threat | B. A measure that reduces threats or vulnerabilities. |
| 3. Vulnerability | C. Something worth protecting. |
| 4. Safeguard | D. A potential source of harm to an asset. |
| 5. Risk | E. An indication of the importance of an asset. |
| 6. Residual risk | F. A need for protection arising from identified risk. |
| 7. Protection requirement | G. The possibility and consequences of harm, depending on assets, threats, vulnerabilities and safeguards. |
| 8. Value | H. Risk that remains after safeguards are applied. |

b) Give concrete examples for each term from task 1.a.

c) Use Figure 1 to put the terms in relation.

Use the following relations (for some multiple usage is allowed):

- exploit - increase - protect against - have - expose - are met by - indicate

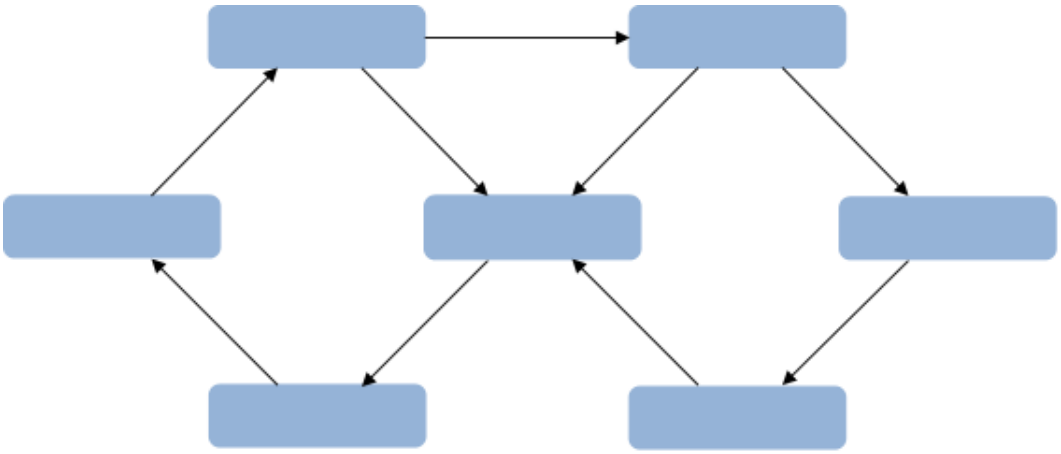


Abbildung 1: Relations of Terms

d) Which three elements of security are presented in the lecture? Explain these elements in your own words!

## Topic 2: Classification of Attackers

a) Why are attackers classified as indicated in the lecture?

b) Give an example for each of these classes!

c) A university operates an online examination system. Consider the following potential adversaries:

**Profile A — External observer**
Can monitor traffic on a public Wi-Fi network, but has no authorised account.

**Profile B — Student account holder**
Has a valid student account and can submit examination registrations, but is not authorised to change grades.

**Profile C — System administrator**
Has privileged access to the system and its database, but must follow university policy.

(a) Rank these profiles by their *potential access privileges*. Why does access alone not determine how dangerous an attacker is?

(b) For each profile, describe one plausible misuse of its capabilities and the security goal primarily threatened.

(c) Select a safeguard for each misuse and explain one important limitation (residual risk) of that safeguard.

(d) Explain why the same defence cannot address all three profiles equally well.

## Question 3: Information Security

a) The Faulty Sensor

An IoT temperature sensor in a university laboratory is defective and reports 43 °C when the actual temperature is 23 °C. The device digitally signs its measurements. The signed value reaches the server without alteration, and the signature verifies successfully.

(a) Has the *signed message* been modified in transit? What does successful signature verification tell the server in this scenario?

(b) Does the reported temperature necessarily describe the real world correctly? Distinguish *data integrity* from the *accuracy of the measurement*.

(c) Identify an asset, a vulnerability or fault, a possible risk, and one safeguard.

b) Policy, Mechanism and Assurance

A university states: "Only authorised examiners may modify students' grades." It enforces this with access controls. Before deploying the system, administrators test that student accounts cannot modify grades.

(a) Identify the **policy**, **mechanism** and **assurance** activity described above.

(b) Why is a security mechanism alone not sufficient to claim that a system is secure?